

{org.name} ABN {org.abn}

Information Management Policy

1. Introduction

1.1 Purpose

This Policy and the Policies and Procedures and related documentation set out in section 1.5 below (**Related Documentation**) supports {org.name} to apply the Information Management NDIS Practice Standard.

1.2 Policy Aims

{org.name} is committed to ensuring that management of each participant’s information ensures that it is identifiable, accurately recorded, current and confidential. Each participant’s information is easily accessible to the participant and appropriately utilised by relevant workers.

1.3 NDIS Quality Indicators

In this regard, {org.name} aims to demonstrate each of the following quality indicators through the application of this Policy and the relevant systems, procedures, workflows and other strategies referred to in this Policy and the Related Documentation:

Information Management

- (a) Each participant’s consent is obtained to collect, use and retain their information or to disclose their information (including assessments) to other parties, including details of the purpose of collection, use and disclosure. Each participant is informed in what circumstances the information could be disclosed, including that the information could be provided without their consent if required or authorised by law.
- (b) Each participant is informed of how their information is stored and used, and when and how each participant can access or correct their information, and withdraw or amend their prior consent.
- (c) An information management system is maintained that is relevant and proportionate to the size and scale of the organisation and records each participant’s information in an accurate and timely manner.
- (d) Documents are stored with appropriate use, access, transfer, storage, security, retrieval, retention, destruction and disposal processes relevant and proportionate to the scope and complexity of support delivered.

1.4 Scope

- (a) This Policy applies to the provision of all services and supports at {org.name}.
- (b) All permanent, fixed term and casual staff, contractors and volunteers are required to take full responsibility for ensuring full understanding of the commitments outlined in this Policy.

1.5 Related Documentation

The application of the above NDIS Practice Standard by {org.name} is supported in part by and should be read alongside the Policies and Procedures and related documentation corresponding to this Policy in the Policy Register.

2. Definitions

2.1 Definitions

In this Policy:

Approved By: The board of {org.legal_name}	Version 1
Approval Date: 16 October 2025	Next Scheduled Review: October 2027

{org.name} means {org.legal_name} ABN {org.abn}.

Client means a client of {org.name} (including an NDIS participant).

Key Management Personnel means {org.primary_contact.name}, {org.signatory.name} and other key management personnel involved in {org.name} from time to time.

Legislation Register means the register of legislation, regulations, rules and guidelines maintained by {org.name}.

Personal information means information or an opinion (whether true or not and whether recorded in a material form or not) about an individual who is identified or reasonably identifiable from the information.

Policy Register means the register of policies of {org.name}.

Principal means {org.primary_contact.name} and {org.signatory.name}.

Related Documentation has the meaning given to that term in section 1.1.

Sensitive information is a subset of personal information that is generally afforded a higher level of privacy protection. Sensitive information includes health and genetic information and information about racial or ethnic origin, political opinions, membership of a political association, religious beliefs or affiliations, philosophical beliefs, membership of a professional or trade association or trade union, sexual preferences or practices, criminal record and some types of biometric information.

Worker means a permanent, fixed term or casual member of staff, a contractor or volunteer employed or otherwise engaged by {org.name} and includes the Principal.

3. Policy Statement

3.1 Consent to collection, use and retaining and disclosing Client information

Client's consent must be obtained to collect, use and retain their information or to disclose their information (including assessments) to other parties, including details of the purpose of collection, use and disclosure. Such consent is obtained in accordance with:

- (a) the Privacy Consent Form; and
- (b) the Service Agreement between {org.name} and the Client.

The Privacy Consent Form informs Clients that their information could be disclosed or provided without their consent if required or authorised by law.

3.2 How is information stored and used?

- (a) {org.name} holds personal information in a number of ways, including in hard copy documents, electronic databases, email contact lists, and in paper files held in drawers and cabinets. Paper files may also be archived in boxes and stored offsite in secure facilities.
- (b) {org.name} must take reasonable steps to:

Approved By: {org.legal_name}	The Board of	Version	1
Approval Date: 16 October 2025		Next Scheduled Review: October 2027	

- (1) make sure that the personal information that {org.name} collects, uses and discloses is accurate, up to date and complete and (in the case of use and disclosure) relevant;
 - (2) protect the personal information that {org.name} holds from misuse, interference and loss and from unauthorised access, modification or disclosure; and
 - (3) destroy or permanently de-identify personal information that is no longer needed for any purpose that is permitted by the Australian Privacy Principles, subject to other legal obligations and retention requirements applicable to {org.name}.
- (c) {org.name} employees must only access and use personal information for a valid work purpose. When handling personal information, employees should:
- (1) confirm recipient details before sending faxes or emails;
 - (2) always store any hard copies of confidential information that is not being used in a secure cabinet or room;
 - (3) be aware of the surroundings and people nearby;
 - (4) limit taking hard copy information away from secure sites;
 - (5) secure information when travelling e.g. in briefcase, folder etc.;
 - (6) dispose unneeded copies of information securely; and
 - (7) ensure the information is available to people who need to access it.
- (d) {org.name} employees may only share personal information as set out under this policy and in circumstances permitted under law.

3.3 What third parties does {org.name} disclose personal information to?

{org.name} may disclose personal information to third parties where appropriate for the purposes set out above, including disclosure to:

- (a) {org.name}'s funding providers;
- (b) government and regulatory bodies, including the National Disability Insurance Agency, Medicare, the Department of Social Services, the Department of Health & Human Services, and the Australian Taxation Office;
- (c) people acting on their behalf including their nominated representatives, legal guardians, executors, trustees and legal representatives;
- (d) the police, or to the NDIS Commission, or to comply with compulsory notices from courts of law, tribunals or Government Agencies;
- (e) financial institutions for payment processing;
- (f) referees whose details are provided to {org.name} by job applicants; and
- (g) {org.name}'s contracted service providers, including:
 - (1) information technology service providers
 - (2) invoice processing service providers

Approved By: {org.legal_name}	The Board of	Version	1
Approval Date: 16 October 2025		Next Scheduled Review: October 2027	

- (3) freight and courier services
- (4) external business advisers (such as recruitment advisors, auditors and lawyers).

In the case of these contracted service providers, {org.name} may disclose personal information to the service provider and the service provider may, in turn, provide {org.name} with personal information collected from individuals in the course of providing the relevant products or services.

3.4 How is personal information kept secure?

The steps {org.name} takes to secure the personal information {org.name} holds include:

- (a) website protection measures (such as encryption, firewalls and anti-virus software);
- (b) security restrictions on access to {org.name}'s computer systems (such as login and password protection) and cloud based storage (using Google Drive and OneDrive),
- (c) controlled access to {org.name}'s premises
- (d) personnel security (including restricting the use of personal information by {org.name} employees to those who have a legitimate need to know the information for the purposes set out above); and
- (e) training and workplace policies.

3.5 Information retention

Unless otherwise required by law, all Client records and personal information will be retained for:

- (a) Clients that are adults, at least seven years after the Client ceases to be a client; and
- (b) Clients that are children, at least 25 years after the Client ceases to be a client.

3.6 Information disposal

- (a) Employees should ensure record retention requirements have been met prior to the disposal of any personal information.
- (b) When disposing of personal information, employees should:
 - (1) Place unneeded working documents or copies of information in secure bins or adequate shredders.
 - (2) Ensure any electronic media including computers, hard drives, USB keys etc. are sanitised when no longer required.

3.7 Privacy incidents

Privacy incidents may result from unauthorised people accessing, changing or destroying personal information. Examples of situations from which incidents may arise include:

- (a) the accidental download of a virus onto an agency computer;
- (b) discussing or sharing of personal information on a social networking website such as Facebook;
- (c) loss or theft of a portable storage device containing personal information;

Approved By: {org.legal_name}	The Board of	Version	1
Approval Date: 16 October 2025		Next Scheduled Review: October 2027	

- (d) non-secure disposal of hard copies of personal information (i.e. placing readable paper in recycle bin or hard waste bin);
- (e) documents sent to the wrong fax number or email address; and
- (f) documents sent to a free web-based email account such as Yahoo!, Gmail or Hotmail.

Privacy incidents can:

- (g) occur due to accidental or deliberate actions;
- (h) result from human error or technical failures; and
- (i) apply to information in any form, whether electronic or hard copy.

3.8 Incident reporting

It is vital all privacy incidents are reported as soon as possible so that their impact may be minimised. Employees should be aware of:

- (a) how to identify potential privacy incidents
- (b) the reason for reporting incidents is so their impact can be minimised - not to punish individuals
- (c) the need to report all incidents to their manager as soon as they become aware of them.

{org.name} must report all Client related privacy incidents to the:

- (a) Department of Health and Human Services;
- (b) NDIS Commission
- (c) Office of the Australian Information Commissioner,

as applicable, within one business day of becoming aware of, or being notified of a possible privacy incident, or within one business day of an allegation being made of a potential breach.

A breach of Client privacy may have a major impact, a non-major impact, or be a near miss or an incident with no apparent impact on a Client. In each case, the incident has to be reported and managed in accordance with the Incident Management and Reporting Policy.

3.9 Access and Correction

Clients have a legal right to request access or correction of their personal information held by {org.name}.

Clients may ask individuals to verify their identity before processing any access or correction requests, to ensure that the personal information {org.name} holds is properly protected.

3.10 Complaints

If a Client has a complaint about how {org.name} has collected or handled their personal information, it will be managed in accordance with the {org.name} Feedback and Complaints Management System.

4. General

4.1 Relevant Legislation, Regulations, Rules and Guidelines

Legislation, Rules, Guidelines and Policies apply to this Policy and Related Documentation as set out in the Legislation Register.

4.2 Inconsistency

Approved By: {org.legal_name}	The Board of	Version	1
Approval Date: 16 October 2025		Next Scheduled Review: October 2027	

If and to the extent that the terms of this Policy are or would be inconsistent with the requirements of any applicable law, this Policy is deemed to be amended but only to the extent required to comply with the applicable law.

4.3 Policy Details

Approved By: The Board of {org.legal_name}

Approval Date: 16 October 2025

Next Scheduled Review: October 2027

Version: 1

Approved By: {org.legal_name}	The Board of	Version	1
Approval Date: 16 October 2025		Next Scheduled Review: October 2027	